

Table of Contents

Como se Preparar para uma Auditoria SOC 2

Guia Prático de Prontidão, Controles, Evidências, Testes e Conformidade Contínua

Autor: Alberto (Al) Leiva

Versão: 1.0 - julho de 2026

Licença: CC BY-NC-SA 4.0

Somente uma firma independente de contabilidade pública qualificada pode emitir um relatório SOC 2. Este manual é educacional e não substitui as orientações oficiais da AICPA nem aconselhamento profissional.

Sumário

- 1. Entendendo o SOC 2
- 2. Relatórios Tipo 1 e Tipo 2
- 3. Governança e responsabilidade pela prontidão
- 4. Definição do escopo e dos limites do sistema
- 5. Critérios de Serviços de Confiança e mapeamento de controles
- 6. Avaliação de riscos
- 7. Políticas e padrões
- 8. Controles de acesso lógico
- 9. Gestão de mudanças e desenvolvimento seguro
- 10. Operações de segurança e resposta a incidentes
- 11. Disponibilidade e continuidade de negócios
- 12. Confidencialidade, privacidade e ciclo de vida dos dados
- 13. Gestão de fornecedores e organizações subprestadoras
- 14. Gestão de evidências
- 15. População, amostragem e exceções
- 16. Descrição do sistema
- 17. Trabalho com o auditor de serviços
- 18. Falhas comuns de prontidão
- 19. Plano de prontidão de 30, 60 e 90 dias
- 20. Lista de verificação e projeto de portfólio

1. Entendendo o SOC 2

O SOC 2 é um exame dos controles de uma organização prestadora de serviços relacionados à segurança, disponibilidade, integridade de processamento, confidencialidade ou privacidade.

Um auditor de serviços realiza o exame; a administração prepara a descrição do sistema, apresenta as declarações formais, é responsável pelos controles e fornece as evidências. SOC 2 não é uma certificação de produto nem uma verificação técnica pontual.

- Segurança é o critério comum e integra todo trabalho SOC 2.
- Disponibilidade, integridade de processamento, confidencialidade e privacidade são selecionadas quando relevantes para os compromissos e requisitos do sistema.
- O escopo deve refletir os serviços, componentes, locais, pessoas, processos, dados e organizações subprestadoras importantes para os usuários.

2. Relatórios Tipo 1 e Tipo 2

Um relatório Tipo 1 aborda o desenho e a implementação dos controles em uma data específica. Um relatório Tipo 2 também aborda a eficácia operacional durante um período definido. Clientes frequentemente solicitam o Tipo 2 porque ele demonstra operação sustentada.

- Escolha o tipo conforme as necessidades dos clientes, maturidade, histórico operacional disponível e orientação do auditor.
- Não descreva um controle como operacional durante um período sem evidências completas e consistentes.
- Reserve tempo suficiente para correções antes do início do período de exame.

3. Governança e responsabilidade pela prontidão

A prontidão SOC 2 é um programa multifuncional. Segurança pode coordenar, mas a operação dos controles e as evidências normalmente dependem de engenharia, TI, recursos humanos, jurídico, privacidade, finanças, instalações, atendimento ao cliente e liderança executiva.

- Nomeie patrocinador executivo, líder do programa, proprietários de controles, responsáveis por evidências, proprietário da descrição do sistema e responsáveis por correções.
- Crie uma matriz RACI e reuniões recorrentes de prontidão.
- Escalone cedo evidências atrasadas, correções vencidas e mudanças de escopo sem controle.

4. Definição do escopo e dos limites do sistema

Um escopo defensável começa pelos compromissos assumidos com os clientes e pelo sistema usado para cumpri-los. Evite incluir apenas a aplicação de produção e ignorar identidades de suporte, serviços em nuvem, processos de atendimento, pipelines de desenvolvimento, monitoramento ou fornecedores críticos.

- Documente produtos e serviços incluídos.
- Identifique infraestrutura, software, pessoas, procedimentos e dados.
- Defina limites físicos e lógicos.
- Liste organizações subprestadoras e escolha, com o auditor, apresentação por exclusão ou inclusão.
- Documente controles complementares que as entidades usuárias devem executar.

5. Critérios de Serviços de Confiança e mapeamento de controles

Mapeie riscos e controles aos Critérios de Serviços de Confiança aplicáveis sem tratar os critérios como lista de tecnologias obrigatórias. Os controles devem responder aos riscos, compromissos e requisitos reais da organização.

- Comece pelos riscos e compromissos e depois identifique os controles.
- Mapeie cada controle a um ou mais critérios e explique a relação.
- Evite controles duplicados com nomes diferentes, salvo quando as atividades forem realmente distintas.
- Use os pontos de foco como considerações de implementação, não como controles obrigatórios separados.

6. Avaliação de riscos

Um programa SOC 2 precisa de processo documentado para identificar objetivos, ameaças, vulnerabilidades, riscos de fraude, mudanças, terceiros e impactos potenciais. A avaliação deve orientar o desenho dos controles e ser atualizada após mudanças relevantes.

- Defina critérios de risco e responsabilidades.
- Relacione riscos a controles e decisões de tratamento.
- Inclua riscos de nuvem, identidade, cadeia de suprimentos de software, privacidade, disponibilidade e ameaças internas.
- Registre riscos aceitos e a aprovação da administração.

7. Políticas e padrões

Políticas estabelecem expectativas da administração; padrões e procedimentos explicam como o trabalho é executado. Uma política não comunicada, aprovada, revisada e sustentada por evidências operacionais é uma evidência fraca.

- Mantenha versão, proprietário, aprovador, data de vigência e data de revisão.
- Treine as pessoas afetadas.
- Relacione as declarações das políticas aos controles implementados.
- Remova documentos obsoletos ou contraditórios.

8. Controles de acesso lógico

Os controles devem abranger usuários da força de trabalho, usuários privilegiados, contas de serviço, aplicações, agentes, contratados e terceiros durante todo o ciclo de vida.

- Documente admissão, mudança de função e desligamento.
- Exija autenticação forte e proteja acessos privilegiados.
- Revise acessos periodicamente.
- Monitore contas inativas, compartilhadas, emergenciais e não humanas.
- Preserve evidências de solicitações, aprovações, provisionamento, revisões e remoções.

9. Gestão de mudanças e desenvolvimento seguro

Os controles de mudança devem demonstrar que alterações são autorizadas, testadas, revisadas, rastreáveis e, quando apropriado, separadas da aprovação de produção.

- Use chamados ou solicitações de alteração com aprovações.
- Proteja branches de produção e credenciais de implantação.
- Documente mudanças emergenciais e revisão posterior.
- Relacione correção de vulnerabilidades e atualização de dependências aos registros de mudança.
- Preserve evidências de implantação durante todo o período de exame.

10. Operações de segurança e resposta a incidentes

Monitoramento de segurança, gestão de vulnerabilidades, triagem de eventos, resposta a incidentes e lições aprendidas devem funcionar como processo integrado.

- Defina severidade e escalonamento.
- Preserve varreduras, registros de correção, alertas, casos, linhas do tempo e análises pós-incidente.
- Teste o plano de resposta a incidentes.
- Acompanhe problemas recorrentes e ações corretivas.

11. Disponibilidade e continuidade de negócios

Quando disponibilidade estiver no escopo, os controles devem abranger capacidade, resiliência, backups, recuperação, monitoramento e compromissos de continuidade.

- Defina objetivos de recuperação alinhados aos compromissos com clientes.
- Teste restauração, e não apenas a conclusão do backup.
- Exercite planos de continuidade de negócios e recuperação de desastres.
- Documente incidentes, indisponibilidade, tendências de capacidade e ações corretivas.

12. Confidencialidade, privacidade e ciclo de vida dos dados

Confidencialidade protege informações classificadas como confidenciais. Privacidade trata informações pessoais durante coleta, uso, retenção, divulgação e descarte. As categorias se sobrepõem, mas não são equivalentes.

- Inventarie dados sensíveis e pessoais.
- Defina classificação, retenção, exclusão, criptografia e regras de acesso.
- Revise compartilhamento de dados e contratos com subprocessadores.
- Documente avisos, escolhas, solicitações e procedimentos de incidentes quando privacidade estiver no escopo.

13. Gestão de fornecedores e organizações subprestadoras

As organizações continuam responsáveis por compreender dependências de provedores de nuvem, processadores, fornecedores de suporte e outras organizações subprestadoras.

- Realize diligência baseada em risco antes da contratação.
- Revise contratos e compromissos de segurança.
- Obtenha e avalie relatórios de asseguarção relevantes.
- Acompanhe controles complementares das organizações subprestadoras.
- Monitore mudanças, incidentes, desempenho e encerramento.

14. Gestão de evidências

Boa evidência é relevante, completa, exata, atribuível, limitada no tempo e protegida contra alteração. Capturas de tela isoladas costumam ser fracas porque podem não mostrar população, período, proprietário, aprovação ou histórico operacional.

- Defina requisitos de evidência para cada controle antes do período.
- Preserve populações e exportações geradas pelos sistemas.
- Registre fonte, proprietário, data, escopo e revisor.
- Proteja evidências confidenciais e controle o acesso do auditor.
- Use nomenclatura consistente e um índice de evidências.

15. População, amostragem e exceções

Para controles recorrentes, o auditor pode selecionar amostras de uma população completa. A administração deve produzir a população integral e explicar como foi gerada.

- Reconcilie quantidades com os sistemas de origem.
- Não selecione nem remova itens com falha.
- Investigue exceções e identifique causa raiz.
- Diferencie lacunas isoladas de evidência de falhas de controle.
- Documente correção e necessidade de testes adicionais.

16. Descrição do sistema

A administração prepara a descrição do sistema da organização prestadora de serviços. Ela deve ser exata, equilibrada e coerente com as operações e compromissos reais.

- Descreva serviços, limites, infraestrutura, software, pessoas, procedimentos, dados e eventos significativos.
- Explique critérios aplicáveis, atividades de controle, organizações subprestadoras e controles complementares das entidades usuárias.
- Evite linguagem de marketing que exagere capacidades.
- Atualize a descrição quando o sistema mudar.

17. Trabalho com o auditor de serviços

Selecione uma firma de contabilidade qualificada, com experiência no setor e na tecnologia. Alinhe escopo, cronograma, critérios, tipo de relatório, tratamento de subprestadores, marcos, métodos de evidência e protocolos de comunicação.

- Forneça informações exatas e divulgue incidentes ou problemas de controle conhecidos.
- Esclareça solicitações cedo, em vez de enviar documentos não relacionados.
- Acompanhe solicitações, perguntas, exceções e respostas da administração.
- A administração é responsável pela prontidão; o auditor deve permanecer independente.

18. Falhas comuns de prontidão

Problemas frequentes incluem escopo impreciso, populações ausentes, controles apenas no papel, aprovações inconsistentes, evidências criadas posteriormente, acessos obsoletos, recuperação não testada e afirmações sem suporte na descrição do sistema.

- Faça avaliação de lacunas antes do período.
- Simule coletas de evidências.
- Teste controles antes de depender deles.
- Não congele o sistema nem o processo de evidências; use gestão de mudanças.
- Trate exceções repetidas como problemas sistêmicos.

19. Plano de prontidão de 30, 60 e 90 dias

Um roteiro prático ajuda a organização a evoluir de controles fragmentados para um modelo operacional auditável.

- Dias 1-30: confirme a necessidade de negócio, defina escopo preliminar, atribua responsáveis, inventarie sistemas, mapeie compromissos e identifique lacunas críticas.
- Dias 31-60: finalize a matriz de controles, corrija lacunas de alto risco, estabeleça procedimentos de evidência, redija a descrição do sistema e realize testes simulados.
- Dias 61-90: opere controles consistentemente, resolva exceções, valide populações, conclua a revisão de prontidão e confirme o cronograma com o auditor.

20. Lista de verificação e projeto de portfólio

A decisão final de prontidão deve ser baseada em evidências. Para um projeto seguro de portfólio, estudantes podem criar uma organização fictícia, declaração de escopo, registro de riscos, matriz de controles, índice de evidências, revisão de acesso de exemplo, registro de exercício de incidente e esboço sanitizado da descrição do sistema.

- Nunca publique evidências confidenciais de clientes, dados reais de funcionários, capturas de produção, segredos ou papéis de trabalho reais.
- Identifique claramente artefatos fictícios.
- Explique premissas, limitações e como cada controle reduz um risco declarado.

Referências oficiais

- [Visão geral da AICPA sobre SOC para organizações de serviços](#)
- [Recursos SOC 2 da AICPA](#)
- [Guia de relatórios SOC 2 da AICPA](#)